计算机(信息)系统安全导论

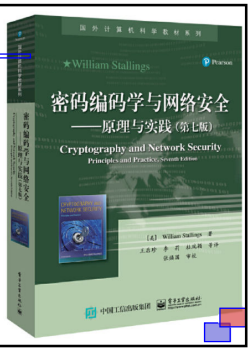
主讲人　曹华
138086900@QQ.com

使用教材

作者：朱建明、王秀利
信息安全导论
清华大学出版社
书号（ISBN）：
978-7-302-41057-7

参考教材

密码编码学与网络安全-原理与实践
（第七版）电子工业出版社
2017年12月第5版(原著第7版)
ISBN：978-7-121-32921-0



教学内容

计算机(信息)系统安全概述
加密技术
操作系统安全
软件安全
Web安全
IoT/云/大数据安全

考核要求

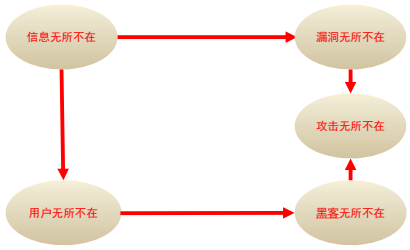
- 考试成绩（课堂教学、实验上机内容）
  70%
- 平时成绩（出勤、实验等情况）
  30%

第1章 概述

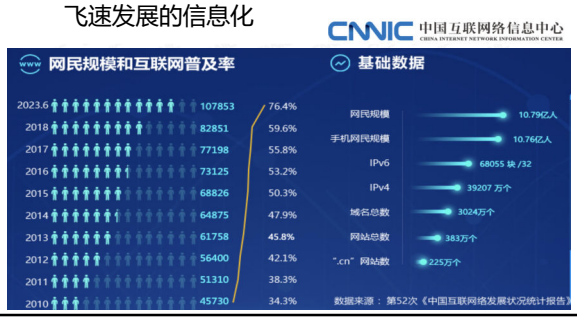
主要内容

- 信息系统安全概况
- 安全攻击示例
- 安全攻击方法概述
- 认识计算机(信息)系统安全
- 安全系统基本概念

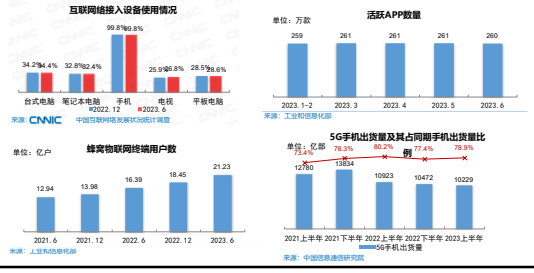
信息系统安全形势



飞速发展的信息化



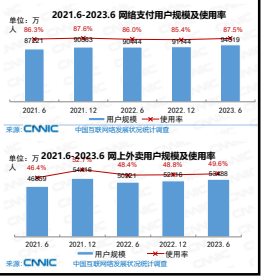
信息化改变生活方式



信息化改变生活方式

2022.12-2023.6各类互联网应用用户规模和网民使用率

应用	2022.12 用户规模（万人）	2022.12 网民使用率	2023.6 用户规模（万人）	2023.6 网民使用率	增长率
即时通信	103,807	97.2%	104,693	97.1%	0.9%
网络视频（含短视频）	103,057	96.5%	104,437	96.8%	1.3%
短视频	101,185	94.8%	102,639	95.2%	1.4%
网络支付	91,144	85.4%	94,319	87.5%	3.5%
网络购物	84,529	79.2%	88,410	82.0%	4.6%
搜索引擎	80,166	75.1%	84,129	78.0%	4.9%
网络新闻	78,325	73.4%	78,129	72.4%	-0.3%
网络直播	75,065	70.3%	76,539	71.0%	2.0%
网络音乐	68,420	64.1%	72,583	67.3%	6.1%
网络游戏	52,168	48.9%	54,974	51.0%	5.4%
网络文学	49,233	46.1%	52,825	49.0%	7.3%
网上外卖	52,116	48.8%	53,488	49.6%	2.6%
线上办公	53,962	50.6%	50,748	47.1%	-6.0%
网约车	43,708	40.9%	47,199	43.8%	8.0%
在线旅行预订	42,272	39.6%	45,363	42.1%	7.3%
互联网医疗	36,254	34.0%	36,416	33.8%	0.4%
网络音频[5]	31,836	29.8%	32,081	29.7%	0.8%



信息安全形势严峻

- 据美国金融时报报道，世界上平均每20秒就发生一次入侵国际互连网的计算机安全事件。
- 据早期的《中国互联网状况》白皮书报道，我国2009年被境外控制的计算机IP地址达100多万个，被篡改的网站4.2万个，被蠕虫病毒感染的计算机每月达1800万台，成为世界上被黑客攻击的主要受害国。
- “棱镜门”事件

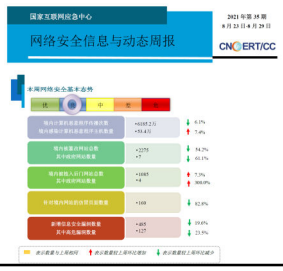
信息安全形势严峻

年份	攻击行为发起者	损失金额 (美元)
1998	CIH病毒	8000万美元
1999	梅利莎(Melissa)	全球约3亿~6亿美元
2000	Love Letter	88亿
2001	红色代码	26亿
2003	Worm_MSBLAST（冲击波）	上百亿
2004	WORM_SASSER.C（震荡波）	损失还在继续
2006	熊猫烧香病毒	上亿
2007	网游大盗	千万
2010	震网病毒	伊朗60%电脑
2014	Heartbleed (心脏滴血)	三分之二的网站
2017	WannaCry	150国家，30万用户，8B$
2018	Meltdown, Spectre	CPU漏洞

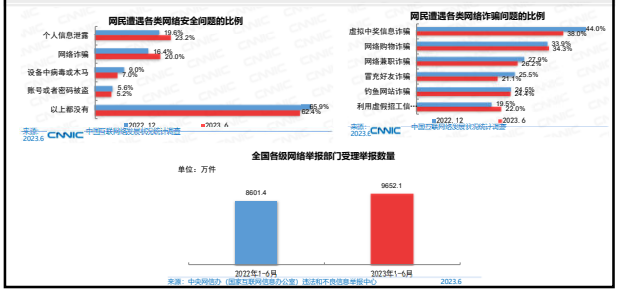
12/17/2023

信息安全形势严峻 https://www.cert.org.cn/

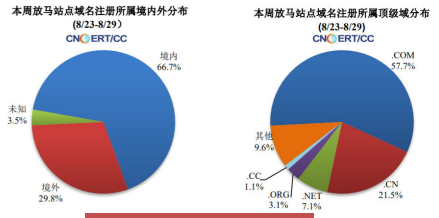
互联网安全形势 https://www.cert.org.cn/



信息安全形势严峻



网站放马



大部分放马站点是通过域名访问

通过 IP 直接访问的涉及 248 个

网站放马

针对 CNCERT 自主监测发现以及各单位报送数据，CNCERT 积极协调域名注册机构等进行处理，同时通过 ANVA 在其官方网站上发布恶意地址黑名单。

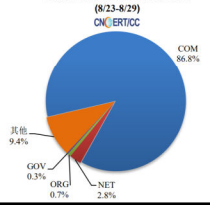
ANVA网络安全威胁信息共享平台

https://share.anva.org.cn/web/publicity/listurl

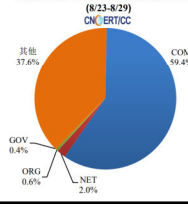
篡改网站/植入后门

本周境内被篡改政府网站（GOV 类）数量为 7 个（约占境内 0.3%），与上周相比下降 61.1%；境内被植入后门的政府网站（GOV 类）数量为 4 个（约占境内 0.4%），与上周相比上升 300.0%。

本周我国境内篡改网站按类型分布
(8/23-8/29)
CNCERT/CC



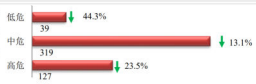
本周我国境内被植入后门网站按类型分布
(8/23-8/29)
CNCERT/CC



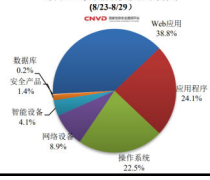
安全漏洞

本周重要漏洞情况

本周，国家信息安全漏洞共享平台（CNVD）新收录网络安全漏洞 485 个，信息安全漏洞威胁整体评价级别为中。



本周CNVD收录漏洞按影响对象分布
(8/23-8/29)
CNVD



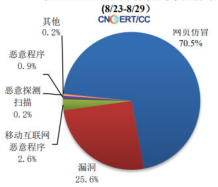
本周 CNVD 发布的网络安全漏洞中，Web 应用占比最高，其次是应用程序和操作系统。

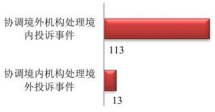
安全事件

本周事件处理情况

本周，CNCERT 协调云服务商、域名注册服务机构、应用商店、各省分中心以及国际合作组织共处理网络安全事件 464 起，其中跨境网络安全事件 126 起。

本周CNCERT处理的事件数量按类型分布
(8/23-8/29)
CNCERT/CC



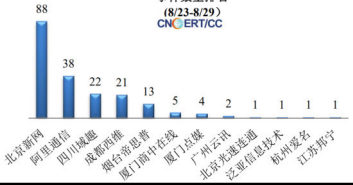


网页仿冒

本周，CNCERT 协调境内外域名注册机构、境外 CERT 等机构重点处理 327 起网页仿冒投诉事件。根据仿冒对象涉及行业划分，银行仿冒事件 294 起，其他事件 33 起。

本周CNCERT处理网页仿冒事件数量按仿冒对象涉及行业统计
(8/23-8/29)
CNCERT/CC

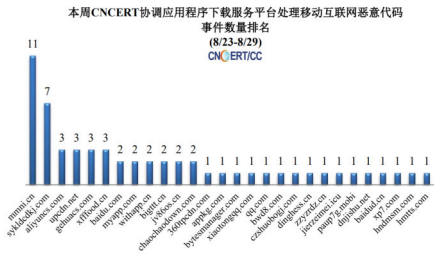
本周CNCERT协调境内域名注册机构处理网页仿冒事件数量排名
(8/23-8/29)
CNCERT/CC



恶意移动APP下载平台

本周，CNCERT 协调 28 个提供恶意移动应用程序下载服务的平台开展移动互联网恶意代码处理工作，共处理传播移动互联网恶意代码的恶意 URL 链接 58 个。

本周CNCERT协调应用程序下载服务平台处理移动互联网恶意代码事件数量排名
(8/23-8/29)
CNCERT/CC



信息化改变战争方式

信息安全事件

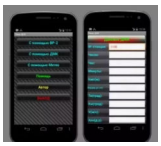
- 海湾战争
  - 被称为“世界上首次全面信息战”，充分显示了现代高技术条件下“控制信息权”的关键作用；
  - 美军通过向带病毒芯片（病毒名为AFgl）的打印机设备发送指令，致使伊拉克防空指挥系统瘫痪，轻易地摧毁了伊军的防空系统；
  - 多国部队运用精湛的信息技术,仅以伤亡百余人的代价取得了歼敌十多万的成果。

信息安全事件

- 科索沃战争
  - 美国的电子专家成功侵入了南联盟防空体系的计算机系统。当南联盟军官在计算机屏幕上看到敌机目标的时候，天空上其实什么也没有。通过这种方法，美军成功迷惑了南联盟，使南联盟浪费了大量的人力物力资源。
  - 北约的计算机通信网因受到“梅利莎”、“疯牛”等病毒攻击而一度陷入瘫痪，美海军陆战队所有作战部门的电子邮件系统均被“梅利莎”病毒阻塞，美“罗斯福”号航母的计算机也曾瘫痪3个小时。

信息安全事件

- 顿巴斯战争(2014)
  - “火控计算机”：Sherstyuk开发的“定位-D30”app，使得长达数分钟之久的火炮射击瞄准流程，在该款应用的协助之下只需要半分钟；
  - 只有Sherstyuk在其博客上发布认证的用户，才能够激活这款软件，发布这款软件的渠道也只能是来自Sherstyuk的社交网站；
  - 俄罗斯黑客组织“梦幻熊”攻击了Sherstyuk的电子邮箱，篡改了“定位-D30”的公开发布版本，植入了后门程序；
  - D-30牵引式榴弹炮的损失，说法不一：从20-30%，到80%。

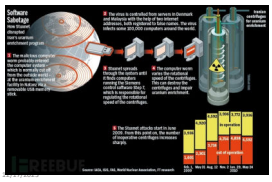


信息安全事件

- 来自杀毒软件提供商ESET 公司的研究人员已经证实，乌克兰电力部门所感染的是一款名为“BlackEnergy（黑暗力量）”的恶意软件，
- 2015 年 12 月 23 日，乌克兰电力网络受到黑客攻击，导致伊万诺-弗兰科夫斯克州数十万户大停电；
- 1 个月后，安全专家表示，证实这起停电是遭到黑客以恶意软件攻击电网所造成；
- 2016 年 1 月 4 日时，安全公司 iSight Partners 宣布已经取得用来造成该起大停电的恶意程序码。

信息安全事件

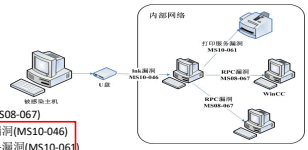
- 2010年，美国&以色列对伊朗
  - 美以研发“震网”(Stuxnet)蠕虫
  - 伊朗60%的电脑感染，目的是攻击伊朗的核电站，导致离心机多次出现故障，从而大大延迟了伊朗的核武器制造计划



信息安全事件

Stuxnet的攻击目标主要是SIMATIC WinCC软件，主要用于工业控制系统的数据采集与监控，一般部署在专用的内部局域网中，并与外部互联网实行物理上的隔离。

为了实现攻击，Stuxnet蠕虫采取多种手段进行渗透和传播。



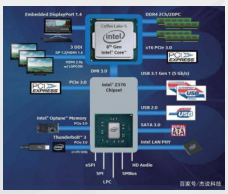
利用的漏洞：

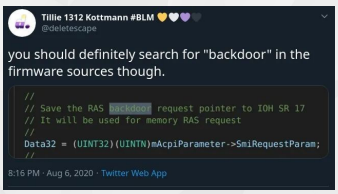
- RPC远程执行漏洞(MS08-067)
- 快捷方式文件解析漏洞(MS10-046)
- 打印机后台程序服务漏洞(MS10-061)
- 内核模式驱动漏洞(MS10-073)
- 任务计划程序漏洞(MS10-092)

硬件面临的威胁

英特尔发生重大机密泄露

•20GB专有数据和源代码疑似遭窃。





信息安全形势严峻

- 新型网络攻击形式
  - 勒索病毒(WannaCry)
  - 供应链攻击(SolarWinds) solarwinds
  - 挖矿病毒
  - …

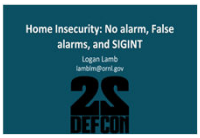
信息安全问题的演进

- 传统信息安全
  - 保护对象：数字资产、服务
  - 保护目标：机密性、完整性
- 现实/未来信息安全
  - 保护对象：物理世界、AI模型。。。
    - 智慧城市、自动驾驶。。。
  - 保护目标：跨介质、模型鲁棒性/隐私性.....

12/17/2023 33

物理世界安全

- 智能家庭和智能家电容易受到黑客攻击，2014 BlackHat大会上来自Trustworthy的Logan展示了智慧家庭中容易遭受攻击者攻击的设备和攻击方法。来自Blue Coat的Felix展示了智能电视设备攻击方法。



物理世界安全

- 针对汽车的攻击
  - 彻底攻破特斯拉汽车
  - 攻击吉普车

  成功攻击后均可完全控制汽车，包括汽车的启动、停止、转向等，也控制了包括媒体系统在内的所有系统

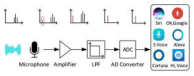
物理世界安全

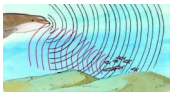
入侵电子路标

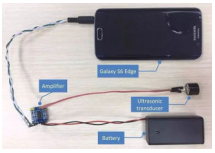
入侵监控摄像机

物理世界安全

海豚攻击



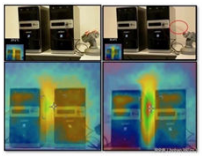




- 攻击者利用声波造成机械硬盘数据存储盘片的振动。
- 如果声波以特定频率播放，则会产生共振效果。最终使硬盘产生暂时或者永久拒绝服务状态。

物理世界安全

BitWhisper攻击



利用计算机内部各个组件的发热量来在两台计算机之间建立一条双向通信信道

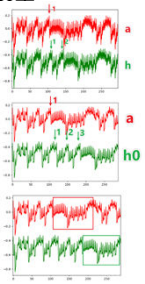
通过无线电波窃取加密密钥

- 向目标设备发送一段经过精心设计的密文
- 当目标计算机在解密时，会触发解密软件内部某些特殊结构的值
- 这些特殊值会导致笔记本电脑周围的电磁场发生比较明显的变化
- 攻击者则可以直接从这些电磁场波动中通过信号处理和密码分析技术推导出密钥

https://blog.csdn.net/SAKAISON/article/details/52457839

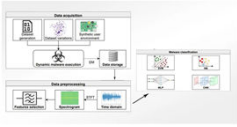
物理世界安全

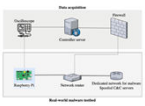
```
int main(void)
{
  char passwd[32];
  char correct_passwd[] = "h0pk1";
  my_readpasswd, 32);
  uint8_t passbad = 0;
  for (uint8_t i = 0; i < sizeof(correct_passwd); i++)
  {
    if (correct_passwd[i] != passwd[i])
    {
      passbad = 1;
      break;
    }
  }
  if (passbad)
  {
    my_puts("PASSWORD FAIL\n");
  }
  else
  {
    my_puts("Access granted, Welcome!\n");
  }
}
```



功耗分析攻击

物理世界安全





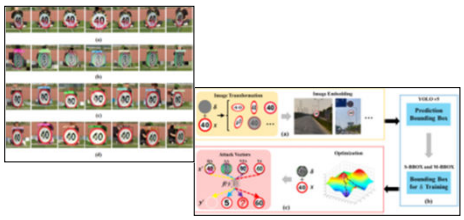
Scenarios	#	MLP				CNN				LDA + NB				LDA + SVM			
		AC [%p]	RC	PR	AC [%p]	RC	PR	AC [%p]	RC	PR	AC [%p]	RC	PR	AC [%p]	RC	PR	
Type	4	99.70 [20]	99.83	99.83	**99.83** [20]	99.80	99.80	99.81 [20]	99.88	99.80	96.06 [20]	96.55	96.09	96.71 [20]	96.71	96.71	
Family	6	99.57 [20]	99.13	99.11	**99.61** [20]	99.61	99.60	97.19 [20]	99.78	98.99	97.27 [20]	91.12	91.14				
Virtualization	2	95.60 [20]	95.56	94.99	**95.93** [20]	96.39	95.16	91.29 [20]	95.87	90.69	91.25 [20]	90.69	90.62				
Packer	2	93.39 [20]	93.36	93.06	**94.96** [20]	94.94	94.70	83.62 [20]	85.15	83.68	83.58 [20]	83.88	83.64				
Obfuscation	2	83.50 [20]	83.50	83.50	**83.50** [20]	83.50	83.50	83.50 [20]	83.50	83.50	83.50 [20]	83.50	83.50				
Executable	10	73.56 [24]	74.66	76.73	**82.28** [24]	83.08	83.11	74.92 [20]	72.89	73.96	74.84 [20]	72.87	72.84				
Novelty (family)	5	88.41 [16]	92.35	91.03	**98.55** [24]	98.59	98.59	95.25 [20]	98.69	98.53	98.62 [20]	98.90	98.82				

- 检测、分类恶意软件
- 识别混淆技术
- 检测规避软件分析手段的隐蔽恶意软件

利用电磁辐射检测IoT设备里隐藏的恶意软件

https://github.com/ahma-hub/analysis/wiki

AI模型安全

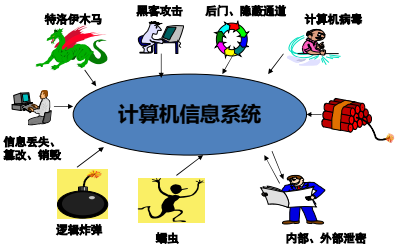


针对真实部署的AI模型的对抗性攻击

主要内容

- 信息系统安全概况
- 安全攻击示例
- 安全攻击方法概括
- 认识信息系统安全
- 安全系统基本概念

安全性攻击

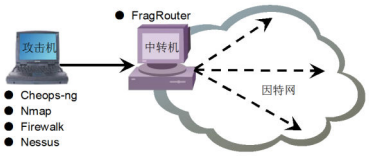


攻击动机的产生

- 媒体文章报道
  - 某公司发展迅速：网点遍布全国
- 寻找有关该公司的IT系统资料
  - 访问互联网信息中心—InterNIC
    - 获知该公司网络IP信息：a.b.c.0~255

为对网络进行扫描作准备

- 寻找替罪机器，为它安装工作软件—FragRouter
  - 拦截发送给网卡的数据，进行重新分片，以规避入侵检测系统，降低被发现的概率。

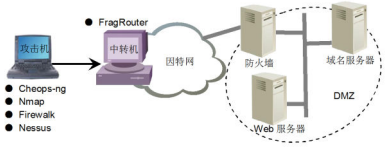


对公司网络进行扫描

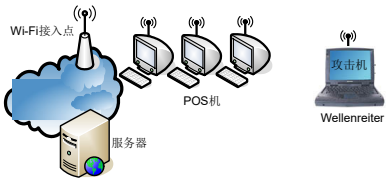
- 用Cheops-ng扫描发现：
  - 有三个系统在运行：一个前端，两个在后。
- 用Nmap作SYN扫描发现
  - 一个TCP 80端口打开-->Web服务器
- 用Nmap作UDP扫描发现：
  - 一个UDP 53端口打开-->DNS服务器
- 用Firewalk作扫描发现：
  - 一个包过滤防火墙：允许通过TCP 80和UDP 53 端口访问公司网络的非军事区（DMZ）
    - DMZ：非安全系统与安全系统之间的缓冲区，放置必须公开的服务器设施，如企业Web服务器、FTP服务器和论坛等

摸清了公司网络的基本布局

- 用Nessus作漏洞扫描发现：
  - DMZ区没有可利用的漏洞



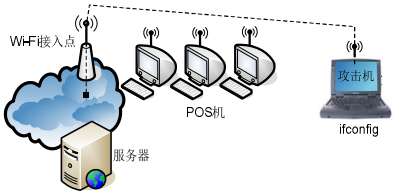
试图探测销售点的无线网络接入



到销售点寻找无线网络接入

- 用Wellenreiter探测无线接入点发现：
  - 一个SSID信息（网络名）：golucorp041
    - 提示：公司名为Good Luck Corporation
- 用该SSID配置无线客户端尝试接入：无响应
- 用ifconfig假冒选定的MAC地址再尝试：
  - 成功接入
  - 被分配了DHCP式的IP

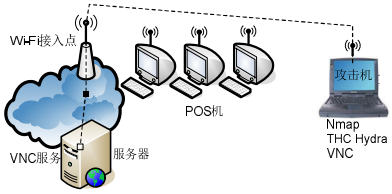
伪造MAC地址接入销售点A的网络



尝试进入系统

- 用Nmap作ping扫描发现：
  - 无线POS机和销售点服务器的IP
- 用dig命令和服务器IP作逆向DNS查询发现：
  - 服务器域名：store041.internal_goodluck.com
- 用Nmap作SYN扫描发现：
  - TCP 5900端口打开--）VNC服务（虚拟网络控制）
- 用THC Hydra猜测VNC服务器口令发现：
  - 帐户：operator
  - 口令：rotarepo

通过VNC进入销售点A的服务器

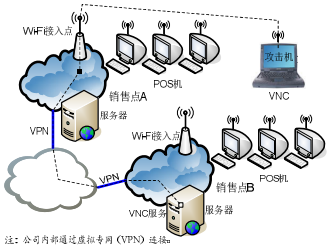


- 登录系统后的收获：
  - 某目录下某文件中的交易记录显示出10万张信用卡资料

尝试进入另一个VNC服务器系统

- 提示：上一台VNC服务器的IP是w.x.y.z
- 尝试w.x.y+1.z：
  - 成功
  - 帐户名与口令与上一台相同
  - 获得又一批信用卡资料

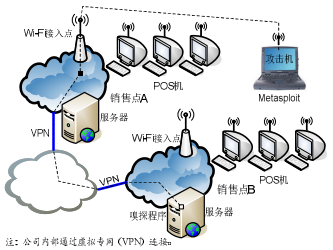
通过VNC进入销售点B的服务器



寻找更有效的攻击机会

- 口令破解的方法不一定总是奏效
- 但是，分析对销售点A的端口扫描结果发现：
  - 该服务器运行一个常用的备份程序
  - 该备份程序有一个缓冲区溢出漏洞
- 用Metasploit对销售点B的服务器上的备份程序进行缓冲区溢出攻击
  - 成功，获得B服务器的shell环境的完全控制权。
  - 在B服务器上安装嗅探程序，发现：
    - B服务器向C服务器发交易授权请求

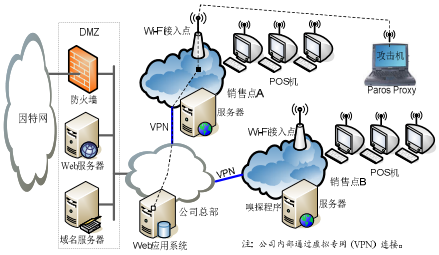
通过缓冲区溢出攻击植入嗅探程序



攻击公司总部系统

- 用Nmap对服务器C（总部）扫描发现：
  - TCP 443端口打开--）HTTPS服务
    - 公司Web业务信息系统
- 尝试登录Web业务信息系统：
  - 尝试原VNC口令失败，THC Hydra口令猜测失败。
- 用Paros Proxy自动扫描Web应用：
  - 寻找跨站脚本和SQL注入缺陷：
    - 在cookie中发现SQL注入缺陷
- 发起SQL注入攻击：
  - 成功，在Web应用后端数据库中获得100万张信用卡资料。

通过SQL注入进入内部Web应用系统



主要内容

- 信息系统安全概况
- 安全攻击示例
- 安全攻击方法概括
- 认识信息系统安全
- 安全系统基本概念

信息安全攻击的主要环节

- 侦察
- 扫描
- 获取访问
- 维持访问
- 掩盖踪迹

APT攻击过程

- 搜索/搜集收集
- 通过购买“肉
- 对目标单位内
- 对贡献的服务

安全攻击的侦察环节

- 社会工程学
- 淘垃圾
- 受害者的Web网站
- 公共信息服务网站：
  - Whois数据库、InterNIC、Uwhois
- DNS服务器
- 侦察工具：Sam Spade等

安全攻击的扫描环节

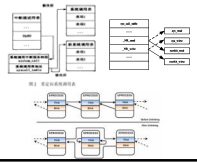
- 网段扫描（网络映射）：Cheops-ng
- 端口扫描：Nmap
- 防火墙扫描：Firewalk
- 无线接入扫描：Wellenreiter
- 拨号扫描：THC-Scan
- 漏洞扫描：Nessus

安全攻击的获取访问环节

- 攻击操作系统
  - 缓冲区溢出攻击、口令攻击
- 攻击Web应用系统
  - 账户捕获、会话捕获、SQL注入、浏览器漏洞
- 攻击网络系统
  - 嗅探、IP欺骗、会话劫持
- 拒绝服务攻击

安全攻击的维持访问环节

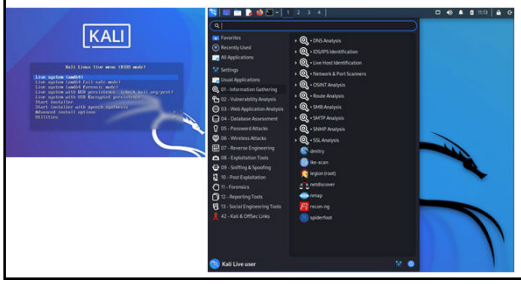
- 木马
- 后门
- 木马后门：
  - 应用层木马后门：远程控制程序、僵尸程序（Bot）、间谍软件
  - 用户态rootkit：替换系统程序
  - 内核态rootkit：
    - 请求重定向
    - 隐藏：
      - 文件/目录隐藏
      - TCP/UDP端口隐藏
      - 进程隐藏



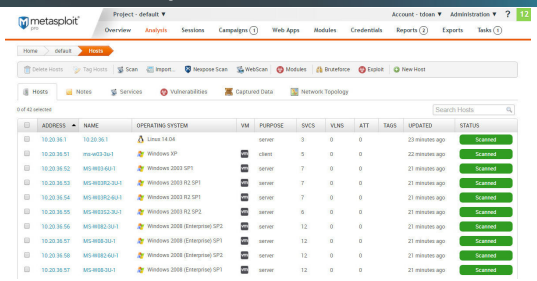
安全攻击的掩盖踪迹环节

- 修改反映攻击行为的日志信息：
  - 失败的登录尝试
  - 特殊账户的使用
  - 安全敏感命令的运行

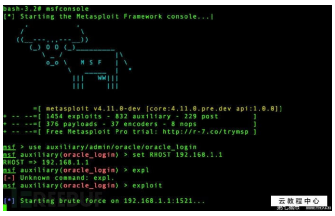
白帽子武器库Kali Linux



Metasploit渗透测试框架



Metasploit渗透测试框架



主要内容

- 信息系统安全概况
- 安全攻击示例
- 安全攻击方法概括
- 认识信息系统安全
- 安全系统基本概念

信息系统与信息安全

- 信息安全是指信息在产生、传输、处理、存储等过程中产生/面临的安全问题。
- 信息安全问题存在于任何一个信息系统中。
- Security/Safety

主机系统与信息系统

- **定义1.1** 由一台计算机的所有硬件和软件构成的整体称为一个主机系统。
- **定义1.2** 由一套应用软件及支撑其运行的所有硬件和软件构成的整体称为一个信息系统。

信息系统安全

- **定义1.5** 信息系统的安全性（Security）指信息系统具有的降低安全攻击风险的特性，它的作用主要体现在以下两个方面：
  （1）降低安全攻击获得成功的可能性；
  （2）降低成功的攻击造成的损害。
- **定理1.2** 主机系统安全与网络安全相结合是信息系统安全的有效方法。

信息系统安全途径

- **推论1.1** 信息系统安全问题具有以下特点：
  （1）涉及硬件安全和软件安全；
  （2）以主机系统安全为核心；
  （3）需要兼顾网络安全。

软件安全

- 计算机系统安全的核心和关键
- 使软件在受到恶意攻击的情况下能够继续正确运行的工程化软件思想
  - 建造健壮的软件，使其在遭受恶意攻击时依然能够安全可靠和正确的运行
- 三个方面
  - 软件自身安全（软件缺陷与漏洞）
  - 恶意软件攻击与检测
  - 软件逆向分析（软件破解）与防护

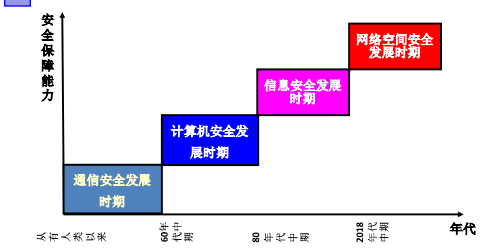
计算机(信息)安全的历史

- 古代、二战前、冷战：保密通讯（军用）
- 60/70年代：
  - 国际贸易发展：民用加密技术(DES、公钥加密)
  - 大型主机系统：多用户系统如何隔离(避免窥探)
  - 安全模型、策略的研究（实现的软件是否安全？）
- 80/90年代（恶作剧、秀技术.....等）
  - PC机：一个设备只有一个用户（没有窥探风险）；出现计算机病毒（引导型病毒、文件型病毒和混合型病毒）
  - 互联网出现，共享服务器依然有窥探风险；通过有线/无线截获信息；蠕虫、木马攻击

计算机(信息)安全的历史

- 2000年以后（经济目的）
  - 黑帽子、白帽子、灰帽子、脚本小子（自动化攻击工具Metasploit、kali Linux、....）.....
  - 恶意程序：病毒 + 蠕虫 + 木马 + ...
  - 基于操作系统或单机应用程序（PE程序/PE病毒）的漏洞Vulnerable：漏洞攻击或漏洞利用exploit从而入侵、控制别人的电脑。
  - Web应用程序的漏洞： exploit入侵服务器或客户端
- 20xx年以后（政治目的）
  - Rootkit
  - APT (Advanced Persistent Threat)“**高级持续性威胁**”

计算机(信息)安全发展的四个阶段

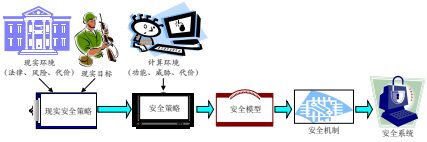


网络安全观

主要内容

- 信息系统安全概况
- 安全攻击示例
- 安全攻击方法概括
- 认识信息系统安全
- 安全系统基本概念

从安全问题到安全系统



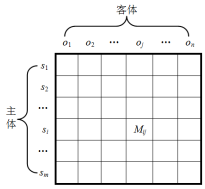
安全策略定义

- **定义1.9** 安全策略是指规定一个组织为达到安全目标如何管理、保护和发布信息资源的法律、规章和条例的集合。
- **定义1.10** 安全策略是指为达到一组安全目标而设计的规则的集合。
- **定义1.11** 安全策略是指关于允许什么和禁止什么的规定。

安全模型定义

- **定义1.12** 安全模型是指拟由系统实施的安全策略的形式化表示。
- **定义1.13** 安全模型是指用更加形式化的或数学化的术语对安全策略的重新表述。
- **定义1.14** 在访问行为中，主动发起访问操作的实体称为主体，被动接受访问操作的实体称为客体。

访问控制矩阵模型

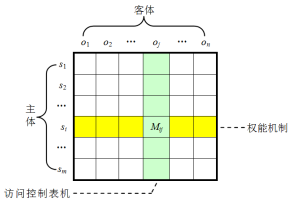


M_{ij} 表示权限集合，描述主体 s_i 拥有的访问客体 o_j 的权限。

安全机制定义

- **定义1.15** 安全机制是指实现安全功能的逻辑或算法。
- **定义1.16** 安全机制是指在硬件和软件中实现特定安全实施功能或安全相关功能的逻辑或算法。
- **定义1.17** 安全机制是指实施安全策略的方法、工具或规程。

权能机制和访问控制表机制



M_{ij} 表示权限集合，描述主体 s_i 拥有的访问客体 o_j 的权限。

安全机制设计八大原则

① 经济性原则（Economy of Mechanism）
② 默认拒绝原则（Fail-Safe Defaults）
③ 完全仲裁原则（Complete Mediation）
④ 开放设计原则（Open Design）
⑤ 特权分离原则（Separation of Privilege）
⑥ 最小特权原则（Least Privilege）
⑦ 最少公共机制原则（Least Common Mechanism）
⑧ 心理可接受原则（Psychological Acceptability）

安全机制设计八大原则

① 经济性原则（Economy of Mechanism）
- 安全机制设计尽可能简单和短小；
- 从而在排查缺陷、检测漏洞时，代码审查更容易处理

② 默认拒绝原则（Fail-Safe Defaults）
- 只要没有授权信息，就不允许访问
- 本该允许的请求被拒绝 vs. 本该拒绝的请求被允许

③ 完全仲裁原则（Complete Mediation）
- 授权检查覆盖任何一个访问操作
- 要求：安全机制有能力标识访问操作请求的所有源头；能够对待为了提高性能而缓存的检查结果

安全机制设计八大原则

④ 开放设计原则（Open Design）
- 不将安全机制的设计作为秘密，不将系统安全性寄托在保守安全机制设计秘密的基础上
- 应在公开安全机制设计方案的前提下，借助容易保护的特定元素，如密钥、口令等，增强系统的安全性
- 开放设计，有助于安全机制接收广泛审查

⑤ 特权分离原则（Separation of Privilege）
- 细分特权，分配给多个主体，减少每个特权拥有者的权力

安全机制设计八大原则

⑥ 最小特权原则（Least Privilege）
- 每个程序和每个用户应只拥有完成工作所需特权的最小集合
- 限制由意外或错误引起的破坏；将特权程序之间的潜在交互数降低到正确操作所需的最小值，尽量避免非经意、不必要、不恰当的使用特权

⑦ 最少公共机制原则（Least Common Mechanism）
- 将多个用户共用和被全体用户依赖的机制的数量减到最少

⑧ 心理可接受原则（Psychological Acceptability）
- 安全机制的良好交互性、安全目标与安全机制的吻合性
- 举例：口令系统

信息系统安全防护基本原则

- 整体性原则
  - 从整体上构思和设计信息系统的安全框架，合理选择和布局信息安全的技术组件，使它们之间相互关联、相互补充，达到信息系统整体安全的目标。

信息系统安全防护的基本原则

信息安全领域的木桶原理

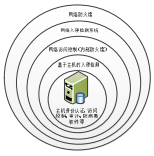
木桶原理

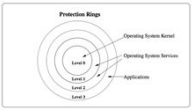
木桶的最大容量不是取决于最长的木板，而是取决于最短的木板

信息安全是系统工程，只有确保每个环节的安全才能确保整个系统的安全

信息系统安全防护基本原则

- 分层性原则
  - 保障信息系统安全不能依赖单一的保护机制
  - 信息系统中只有构建良好分层的安全措施才能够保证信息的安全





信息系统安全防护基本原则

- 最小特权原则
  - 最小特权（Least Privilege）的思想是系统不应赋予用户超过其执行任务所需特权以外的特权，或者说仅给用户赋予必不可少的特权
  - 管理员权限划分：系统管理员、系统审计员、系统安全员

有关安全的几点认识和观点

- 信息系统究竟满足什么要求才算是安全了呢?
  - 没有绝对的安全！
  - 安全是一个动态的过程！
  - 人往往是安全机制中最薄弱的环节！
  - 系统越安全，给用户带来的不便就越多！